

TLPT Attestation by Competent Authority

Document ID	Version	Owner	Effective Date	Framework	Classification
[DORA-TLPT-ATT-001]	1.0	[Competent Authority TLPT Function]	[DD Month YYYY]	Digital Operational Resilience Act	Confidential

Purpose

This attestation confirms that the threat-led penetration testing performed for [Financial Entity Legal Name] was conducted in accordance with the applicable regulatory requirements for threat-led penetration testing under the Digital Operational Resilience Act.

The purpose of this document is to provide formal confirmation by the competent authority that:

- The entity was subject to a threat-led penetration test within the applicable supervisory cycle.
- The test was planned, governed, executed, and closed in line with the expected regulatory process.
- The test used a threat-led, intelligence-driven approach and covered critical or important functions and supporting ICT systems within the agreed scope.
- Required stakeholders, including the control team, testers, threat intelligence providers, and the competent authority, performed their respective roles.
- The test outcome was appropriately documented and remediation was initiated or tracked by the entity.
- The competent authority has reviewed the relevant evidence and is satisfied that the test has been conducted in accordance with the applicable requirements.

This attestation is intended for regulatory, supervisory, governance, and audit purposes. It does not certify the complete security of [Financial Entity Legal Name], nor does it eliminate the entity's responsibility to manage ICT risk, remediate identified weaknesses, and maintain digital operational resilience on an ongoing basis.

Scope

This attestation applies to the threat-led penetration test conducted for [Financial Entity Legal Name] during the period [Start Date] to [End Date].

The attested test covered the following entity, functions, systems, and arrangements as agreed during the scoping and testing preparation phase.

Scope Area	Description
Financial entity	[Financial Entity Legal Name]
Registered address	[Registered Address]
Legal entity identifier	[LEI or Registration Number]
Competent authority	[Competent Authority Name]
Test reference	[TLPT Reference Number]
Testing period	[Start Date] to [End Date]
Critical or important functions in scope	[List of Functions]
Business services in scope	[List of Services]
ICT assets and environments in scope	[Applications, Platforms, Infrastructure, Cloud Services, Networks, or Environments]
Third-party ICT service providers in scope	[Provider Names or "None"]
Threat intelligence provider	[Provider Name]
Red team provider	[Provider Name]

Scope Area	Description
White team lead	[Name and Role]
Control team representatives	[Names/Roles or Group Name]
Exclusions agreed	[Approved Exclusions and Rationale]
Testing constraints	[Operational, Legal, Safety, Production, or Time Constraints]

The scope included assessment of the entity's ability to prevent, detect, respond to, and recover from realistic cyber threat scenarios targeting critical or important functions. Testing was conducted using controlled methods intended to minimise business disruption while preserving the realism necessary for an effective threat-led assessment.

The attestation is limited to the TLPT process and evidence reviewed by the competent authority. It does not constitute:

- A general assurance opinion over all ICT risks of the entity.
- A certification of all controls, systems, or services operated by the entity.
- A guarantee that all vulnerabilities, attack paths, or resilience weaknesses were identified.
- Approval to defer remediation of identified weaknesses.
- A substitute for the entity's own governance, assurance, incident response, or risk management obligations.

Attestation Statement

Based on the competent authority's oversight of the testing process and review of the referenced evidence, [Competent Authority Name] attests that the threat-led penetration test conducted for [Financial Entity Legal Name] was performed in accordance with the applicable requirements for threat-led penetration testing under the Digital Operational Resilience Act.

The competent authority confirms that, to the extent evidenced and reviewed:

Attestation Area	Competent Authority Confirmation
Eligibility and initiation	The entity was identified as subject to threat-led penetration testing and the test was initiated under the appropriate supervisory process.
Governance and control	A controlled testing governance structure was established, including appropriate white team and control team arrangements.
Scope definition	The scope was defined using the entity's critical or important functions, supporting ICT systems, and relevant third-party dependencies.
Threat-led approach	Testing was informed by threat intelligence relevant to the entity's sector, business model, technology profile, geography, and likely threat actors.
Scenario design	Attack scenarios were designed to reflect realistic threat behaviours and plausible routes to compromise or disruption of critical or important functions.
Testing provider arrangements	The threat intelligence and red team providers were identified and assessed as suitable for the engagement, including independence, capability, confidentiality, and professional competence considerations.
Rules of engagement	Testing boundaries, escalation paths, safety controls, communication protocols, and stop conditions were agreed before active testing.
Conduct of testing	Active testing was performed within the agreed scope, time window, and rules of engagement, subject to approved changes and operational safeguards.
Evidence handling	Testing evidence was handled using agreed confidentiality, integrity, access control, and secure transfer arrangements.
Reporting	The entity received appropriate reporting on test activities, findings, attack paths, observations, and remediation recommendations.
Closure and remediation	The entity prepared or maintained a remediation plan for findings and weaknesses identified through the test.
Supervisory visibility	The competent authority was provided with sufficient information to oversee the process, review key outputs, and determine whether the test met the expected requirements.

The competent authority further confirms that any material deviations from the planned test approach, if applicable, were reviewed and addressed as part of the supervisory process.

Deviation or Exception	Status	Competent Authority Position
[Description or "No material deviations identified"]	[Open/Closed/Not Applicable]	[Accepted / Accepted with Conditions / Not Accepted / Not Applicable]

Where the test identified weaknesses, this attestation confirms that such weaknesses were documented and are subject to remediation tracking by [Financial Entity Legal Name]. This attestation does not state that all findings have been remediated unless expressly confirmed in a separate closure or remediation validation record.

The competent authority’s attestation is made as of [Attestation Date] and is based on evidence available to the competent authority as of that date.

Signatory & Authority

This attestation is issued by the competent authority responsible for supervisory confirmation of the TLPT process for [Financial Entity Legal Name].

Role	Name	Organisation	Authority Basis	Signature	Date
Authorised competent authority representative	[Name]	[Competent Authority Name]	Authorised to issue TLPT supervisory attestations on behalf of the competent authority	[Signature]	[DD Month YYYY]
Reviewer, if applicable	[Name]	[Competent Authority Name]	Reviewed the evidence file and attestation content for completeness and consistency	[Signature]	[DD Month YYYY]

- By signing this attestation, the authorised representative confirms that:
- They are duly authorised to issue this attestation on behalf of [Competent Authority Name].
 - The attestation has been prepared following supervisory review of the evidence referenced in this document.
 - The competent authority has not identified unresolved issues that would prevent confirmation that the TLPT was conducted in accordance with the applicable requirements.
 - Any limitations, exclusions, or accepted deviations have been recorded or referenced in the supervisory file.
 - The attestation is issued for the stated entity, test reference, scope, and testing period only.

- This attestation may be shared with:
- [Financial Entity Legal Name] senior management and management body.
 - Relevant supervisory authorities where permitted or required.
 - Internal and external auditors with a legitimate need to review the TLPT process.
 - Other recipients approved by [Competent Authority Name] in accordance with applicable confidentiality and information-sharing requirements.

Unauthorised disclosure, reproduction, or onward transmission of this attestation or supporting TLPT materials is not permitted.

Evidence Referenced

The competent authority reviewed or relied upon the following evidence in forming this attestation. The evidence set may be held by the competent authority, the entity, testing providers, or other authorised parties, subject to confidentiality and secure handling requirements.

Evidence Item	Document or Record Name	Owner or Custodian	Date / Version	Review Status
TLPT initiation record	[Initiation Notice / Supervisory Confirmation]	[Competent Authority / Entity]	[Date / Version]	Reviewed
Entity scope submission	[Scope Specification]	[Financial Entity Legal Name]	[Date / Version]	Reviewed
Critical or important function mapping	[Function and Service Mapping Record]	[Financial Entity Legal Name]	[Date / Version]	Reviewed
ICT asset and dependency mapping	[ICT Systems and Third-Party Dependency Register Extract]	[Financial Entity Legal Name]	[Date / Version]	Reviewed
Provider suitability documentation	[Threat Intelligence and Red Team Provider Due Diligence Records]	[Financial Entity Legal Name]	[Date / Version]	Reviewed
Threat intelligence report	[Threat Intelligence Report Title]	[Threat Intelligence Provider]	[Date / Version]	Reviewed
Test plan	[TLPT Test Plan]	[Red Team Provider / Entity]	[Date / Version]	Reviewed
Rules of engagement	[Rules of Engagement]	[Red Team Provider / Entity]	[Date / Version]	Reviewed
Risk and safety controls	[Testing Safety and Escalation Plan]	[Financial Entity Legal Name]	[Date / Version]	Reviewed
Legal and contractual approvals	[Authorisation to Test / Provider Contract Extracts]	[Financial Entity Legal Name]	[Date / Version]	Reviewed
Change and deviation log	[TLPT Deviation and Exception Log]	[White Team Lead]	[Date / Version]	Reviewed
Red team activity report	[Red Team Test Report]	[Red Team Provider]	[Date / Version]	Reviewed
Detection and response evidence	[Blue Team / SOC Response Timeline]	[Financial Entity Legal Name]	[Date / Version]	Reviewed
Final TLPT report	[Final TLPT Report]	[Financial Entity Legal Name / Red Team Provider]	[Date / Version]	Reviewed
Findings register	[TLPT Findings Register]	[Financial Entity Legal Name]	[Date / Version]	Reviewed
Remediation plan	[TLPT Remediation Plan]	[Financial Entity Legal Name]	[Date / Version]	Reviewed
Closure meeting record	[TLPT Closure Meeting Minutes]	[Competent Authority / Entity]	[Date / Version]	Reviewed
Management acknowledgement	[Management Body or Senior Management Acknowledgement]	[Financial Entity Legal Name]	[Date / Version]	Reviewed

The competent authority's review focused on whether the testing process was appropriately established, executed, evidenced, and closed from a regulatory assurance perspective. The competent authority did not reperform technical testing and did not independently validate every technical finding unless separately documented.

Any evidence containing sensitive operational details, attack techniques, credentials, exploit paths, system architecture, or vulnerability information must remain protected under the applicable confidentiality classification and handling rules.

Frequency

This attestation is issued following completion of the TLPT cycle for [Financial Entity Legal Name] and applies only to the test referenced in this document.

The entity remains responsible for ensuring that future threat-led penetration testing is performed within the applicable supervisory cycle or sooner where required due to material changes in risk, business operations, technology, threat exposure, or supervisory direction.

Trigger	Expected Action
Completion of a supervised TLPT cycle	Competent authority reviews the evidence file and issues an attestation where requirements have been met.

Trigger	Expected Action
Material change to critical or important functions	Entity assesses whether the TLPT scope or timing should be updated and informs the competent authority where required.
Significant ICT transformation, merger, outsourcing change, or platform migration	Entity evaluates whether the previous TLPT remains representative of current risk exposure.
Major cyber incident or material control failure	Entity assesses whether additional targeted testing, remediation validation, or supervisory engagement is required.
Supervisory request	Entity provides information, evidence, or updated testing plans as requested by the competent authority.
Next scheduled TLPT cycle	Entity initiates planning early enough to complete scoping, provider selection, threat intelligence, testing, reporting, and remediation planning in an orderly manner.

A new attestation is required for each completed TLPT cycle. This attestation must not be reused to represent any later test, changed scope, different legal entity, or materially altered operating environment.

Records & Retention

The competent authority and [Financial Entity Legal Name] must retain this attestation and supporting records in a manner that preserves confidentiality, integrity, availability, and evidential value.

Record Type	Minimum Retention Expectation	Custodian	Handling Requirement
Signed attestation	[Retention Period, e.g., 7 years]	[Competent Authority Name] and [Financial Entity Legal Name]	Confidential; access restricted to authorised supervisory, governance, audit, and risk personnel
Evidence index	[Retention Period]	[Competent Authority Name]	Confidential; maintain version history and review status
Final TLPT report	[Retention Period]	[Financial Entity Legal Name]	Highly restricted; protect technical details and attack paths
Threat intelligence report	[Retention Period]	[Financial Entity Legal Name / Threat Intelligence Provider]	Highly restricted; protect sensitive intelligence sources and entity-specific targeting information
Rules of engagement and authorisations	[Retention Period]	[Financial Entity Legal Name]	Confidential; preserve signed approvals and approved changes
Findings and remediation records	[Retention Period]	[Financial Entity Legal Name]	Confidential; maintain traceability from finding to remediation action and validation status
Closure meeting records	[Retention Period]	[Competent Authority Name / Financial Entity Legal Name]	Confidential; retain agreed actions, decisions, and open items
Communications with competent authority	[Retention Period]	[Competent Authority Name / Financial Entity Legal Name]	Confidential; retain formal correspondence and supervisory submissions

Records must be:

- Stored in approved repositories with access limited to personnel with a documented need to know.
- Protected from unauthorised disclosure, alteration, deletion, or copying.
- Marked with the appropriate confidentiality classification.
- Transferred only through approved secure channels.
- Retained for the required period and disposed of securely when retention obligations expire.
- Made available to authorised supervisory, audit, legal, or governance stakeholders where there is a legitimate and approved need.

Where supporting evidence is held by testing providers or third-party ICT service providers, [Financial Entity Legal Name] must ensure that contractual and operational arrangements allow secure retention, controlled access, and timely provision of records when required.

Any suspected unauthorised access, disclosure, loss, or compromise of this attestation or related TLPT evidence must be escalated immediately through the applicable security incident and regulatory notification processes.